You said:

exec(4).pyc
Code

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 1m 38s >

ChatGPT said:

Análise estática de malware — `exec(4).pyc`

Veredito: MALWARE

O arquivo apresenta evidências fortes de um **ransomware criptográfico**, com recursos adicionais de destruição de dados, evasão de análise, persistência e tentativa de comunicação com um servidor remoto.

A análise foi realizada por inspeção estática do bytecode, sem executar o arquivo. A conclusão se baseia nas rotinas identificadas, nas constantes e no fluxo de execução recuperado.

1. Identificação do arquivo

Propriedade	Resultado
Arquivo	`exec(4).pyc`
Formato	Bytecode compilado de Python
Versão identificada	CPython 3.13
Tamanho	54.248 bytes
Nome interno do código	`36affc7afbcf01664d0f4a129cf4d98a9434ae00cb92d2e6ef3c0aaf605a3bbb.py`
Família/nome declarado no código	Liushen Ransomware PoC
Execução durante a análise	Não realizada

A extensão `.pyc` não torna o arquivo seguro: ela apenas indica que o conteúdo é código Python compilado.

2. Investigação passo a passo

Etapa 1 — Imports e configurações suspeitas

A inspeção revelou dependências e constantes associadas a operações potencialmente maliciosas:

- `Crypto.Cipher.AES` : criptografia de dados.
- `ctypes` , `win32api` e `win32con` : interação com APIs do Windows.
- `subprocess` : execução de comandos do sistema.
- `psutil` : enumeração e encerramento de processos.
- `requests` e `socket` : comunicação de rede e coleta de informações da máquina.
- `threading` : processamento paralelo.

Também foram identificadas as seguintes constantes:

Constante	Valor identificado
`RANSOM_AMOUNT`	`5000`
`EXTENSION`	`.Liushen`
`C2_SERVER`	`http://your-c2-server.com/api`

A combinação entre configuração de resgate, extensão própria para arquivos criptografados e rotinas de criptografia é um forte indicador de ransomware.

Etapa 2 — Criptografia de arquivos

A classe `FileEncryptor` , especialmente o método `encrypt_file` , contém uma rotina concreta de criptografia.

O fluxo recuperado do bytecode é:

1. Seleciona um arquivo
Verifica a existência, a extensão e o tamanho.

↓

2. Gera parâmetros criptográficos
Cria um IV aleatório e deriva uma chave por arquivo com SHA-256.

↓

3. Cifra o conteúdo
Utiliza AES no modo CBC e grava um novo arquivo.

↓

4. Apaga o arquivo original
Sobrescreve os dados com bytes aleatórios e remove o arquivo.

O arquivo resultante recebe a extensão adicional `.Liushen`. O código limita a rotina de criptografia a arquivos de até 50 MiB por arquivo.

A lista de extensões-alvo inclui documentos, planilhas, PDFs, imagens, vídeos, arquivos compactados, bancos de dados, código-fonte, chaves e arquivos de máquinas virtuais.

Por que isso é decisivo? A combinação de criptografia dos dados da vítima com a eliminação dos originais e a extensão característica é comportamento típico de ransomware criptográfico.

Etapa 3 — Destruição e prevenção de recuperação

Foram identificadas rotinas adicionais que ampliam os danos possíveis:

Componente	Comportamento identificado
`ShadowCopyDeleter`	Tenta excluir cópias de sombra do Windows e desativar mecanismos de recuperação.
`MBRLocker`	Tenta sobrescrever o setor de inicialização do disco e gravar uma mensagem de resgate no setor seguinte.
`LiushenRansomware.kill_processes`	Tenta encerrar aplicativos de escritório, bancos de dados, ferramentas de backup e ferramentas de análise.
`LiushenRansomware.disable_security`	Tenta desativar o monitoramento em tempo real do Windows Defender, o firewall e outros mecanismos de segurança.

Essas funções são particularmente perigosas porque podem prejudicar tanto os dados quanto a capacidade de recuperação do sistema.

A rotina de bloqueio do MBR depende de condições como o uso do Windows e privilégios administrativos; portanto, sua presença não prova que a operação terá sucesso em qualquer máquina.

Etapa 4 — Persistência no sistema

A classe `Persistence` reúne métodos para tentar manter a execução após reinicializações ou logins.

As técnicas identificadas incluem:

- Chaves de inicialização do Registro do Windows, como `Run` e `RunOnce`.
- Cópia do executável para a pasta de inicialização do usuário.
- Criação de tarefas agendadas.
- Tentativa de instalação como serviço do Windows.

Esses mecanismos são compatíveis com malware que busca continuar ativo depois da primeira execução. A efetividade de cada método depende das permissões e do ambiente.

Etapa 5 — Comunicação remota e tratamento da chave

A classe `EmailSender` implementa uma tentativa de comunicação HTTP com o endereço configurado em `C2_SERVER`, acrescentando o caminho `/report`.

O relatório preparado contém informações como:

- Identificador da vítima e nome do computador.
- Quantidade de arquivos processados.
- Chave mestra em Base64.
- Endereço IP público e sistema operacional.

Caso as tentativas de comunicação falhem, o código tenta salvar a chave mestra e metadados localmente em um diretório chamado `.sysupdate`, dentro do diretório temporário.

Existem, contudo, ressalvas importantes: o endereço `your-c2-server.com` aparenta ser um marcador de exemplo, e o método SMTP identificado retorna `False` sem implementar o envio. **A tentativa de comunicação remota está presente no código, mas não foi comprovado que um servidor funcional esteja disponível ou que dados tenham sido enviados.**

Etapa 6 — Evasão de análise e tentativa de injeção em processos

A classe `AntiAnalysis` procura sinais de máquinas virtuais, depuradores e ambientes de sandbox. Entre os indicadores avaliados estão nomes de hipervisores, endereços MAC associados a ambientes virtuais, tempo de atividade, memória RAM e recursos da

máquina.

O código também tenta encerrar a execução quando determinadas condições de análise são detectadas.

Além disso, a classe `ProcessHollowing` contém uma rotina para tentar criar um processo suspenso, modificar seu espaço de memória e retomá-lo. O código disponível não permite garantir que essa injeção funcione corretamente em um sistema real, mas a técnica pretendida é compatível com evasão e execução maliciosa.

Etapa 7 — Fluxo principal e limitações

O método `LiushenRansomware.run` conecta os componentes anteriores. O fluxo inclui as verificações anti-análise, tentativas de desativar defesas, encerramento de processos, exclusão de cópias de sombra, criptografia, criação de notas de resgate, persistência e envio de relatório.

O ponto de entrada disponibiliza um modo de criptografia (`--encrypt`) e um modo de descriptografia (`--decrypt`). Entretanto, este último apenas informa que a descriptografia não foi implementada na versão analisada.

Há também possíveis falhas de implementação. Por exemplo, as dependências são importadas no início do módulo, antes de a rotina de verificação e instalação de dependências ser chamada. A ausência de um módulo pode impedir que o programa inicialize.

Essas limitações podem comprometer partes da execução, mas não anulam a evidência de comportamento malicioso.

3. Classificação final

MALWARE — Ransomware criptográfico

Categoria principal

Ransomware (criptografia de arquivos para extorsão).

Capacidades secundárias

Destruição de dados · Anti-recuperação · Persistência · Evasão de análise · Tentativa de C2 · Process Hollowing

Confiança na classificação: alta, com base na análise estática do bytecode. A eficácia de todas as rotinas e a ocorrência de qualquer comunicação externa não foram testadas.

Conclusão: o arquivo `exec(4).pyc` deve ser tratado como malicioso. A evidência mais forte é a implementação de criptografia de arquivos seguida da destruição dos originais, integrada a uma rotina principal que cria notas de resgate e tenta impedir a recuperação do sistema.

Não execute o arquivo em uma máquina real. Se ele já tiver sido executado, isole o equipamento da rede e preserve os arquivos afetados e os registros para análise, evitando ações que possam eliminar evidências ou dificultar a recuperação.

Também posso criar uma imagem explicando visualmente o fluxo do ransomware. ↪ Criar diagrama do ataque

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Ransomware criptográfico**.

Ele cifra os arquivos da vítima, adiciona a extensão `.Liushen` e tenta apagar os arquivos originais, além de apresentar mecanismos para dificultar a recuperação dos dados e exigir um resgate.